

Beveiliging & Gegevensbescherming

Overzicht van technische en organisatorische maatregelen — versie 26 juni 2026

1. OVER DIT DOCUMENT

Dit document beschrijft de beveiligingsmaatregelen die ArnoBot heeft geïmplementeerd om jouw gegevens te beschermen. Het is bedoeld voor gebruikers die willen begrijpen hoe hun data wordt verwerkt, opgeslagen en beveiligd.

2. INFRASTRUCTUUR EN HOSTING

- Hosting: Vercel (serverless, wereldwijd edge-netwerk, HTTPS verplicht)
- Database: Supabase (PostgreSQL, EU-regio, versleuteld in rust en transit via TLS 1.2+)
- Authenticatie: Clerk (SOC 2 Type II gecertificeerd, LinkedIn OAuth)
- AI-verwerking: Anthropic API (berichten worden tijdelijk verwerkt voor het genereren van een antwoord; Anthropic slaat geen gesprekken permanent op)
- E-mail: Resend (transactionele e-mail via DKIM-geverifieerd domein)

3. AUTHENTICATIE EN TOEGANGSBEHEER

- Inloggen verloopt uitsluitend via LinkedIn OAuth via Clerk; wachtwoorden worden nooit door ArnoBot opgeslagen
- Alle beveiligde routes controleren actief de sessie-identiteit via Clerk middleware
- De Supabase service role key is uitsluitend beschikbaar in de serveromgeving en nooit blootgesteld aan de client
- Admin-toegang is beveiligd met een aparte, roteerbare sleutel (httpOnly cookie)
- Admin-inlogpogingen zijn beperkt tot 10 per IP-adres per 15 minuten, met een ingebouwde vertraging na mislukte pogingen
- Cron-jobs zijn beveiligd met een CRON_SECRET header die bij elke aanroep wordt geverifieerd

4. GEGEVENSISOLATIE (IDOR-BESCHERMING)

Insecure Direct Object Reference (IDOR) is een veelvoorkomende kwetsbaarheid waarbij een gebruiker door het aanpassen van een parameter toegang krijgt tot andermans data.

- Elke API-route haalt de gebruikers-ID op uit de geverifieerde sessie, nooit uit de URL of de request-body
- Het PDF-exportendpoint accepteert geen externe user_id parameter; de identiteit wordt altijd uit de actieve sessie gelezen
-

Manager-toegang tot teamgegevens is uitsluitend toegestaan als de manager en het doelaccount aantoonbaar lid zijn van hetzelfde team

5. INVOERVALIDATIE EN INJECTIEBEVEILIGING

- Prompt-injectiedetectie: 14 reguliere expressies detecteren pogingen om het AI-model te manipuleren (NL en EN), inclusief rolwijzigingsopdrachten, data-extractiepogingen en instructie-overrides
- Berichtlengte-limieten: gebruikersvragen max 4.000 tekens, gespreksgeschiedenis max 40 items
- Sparring-module: berichten max 2.000 tekens, context max 500 tekens, geschiedenis max 40 items
- Feedbackveld: max 2.000 tekens, gesanitized voor doorsturen naar externe dienst
- E-mailadressen in formulieren worden gevalideerd via regex voor verwerking
- Alle namen en vrije tekstvelden die als AI-context worden gebruikt, worden afgekapt op veilige maximumlengtes

6. SNELHEIDSLIMIETEN (RATE LIMITING)

- Hoofdchat: max 5 verzoeken per IP-adres per minuut, gemeten via bestaande logtabellen
- Admin-login: max 10 pogingen per IP per 15 minuten
- Teamlidmaatschap: maximaal 25 leden per team om misbruik van AI-resources te voorkomen

7. FOUTAFHANDELING EN INFORMATIEBEVEILIGING

- Interne foutmeldingen (stack traces, databasefouten, API-sleutels) worden nooit aan de gebruiker teruggegeven
- Alle API-routes retourneren generieke foutberichten aan de client; gedetailleerde informatie wordt uitsluitend server-side gelogd
- Dit voorkomt dat aanvallers door middel van foutberichten informatie over de infrastructuur kunnen achterhalen

8. SCANNERBEVEILIGING EN BOT-BLOKKERING

- Veelgebruikte scanpaden worden actief geblokkeerd op middleware-niveau: .env, .git, .htaccess, wp-admin, phpMyAdmin, xmlrpc.php en vergelijkbare paden
- Niet-bestaande beveiligingsgevoelige paden retourneren altijd HTTP 404 zonder aanvullende informatie

9. BEVEILIGINGSHEADERS

Alle HTTP-responses bevatten de volgende headers:

- X-Content-Type-Options: nosniff (voorkomt MIME-type sniffing)
-

X-Frame-Options: DENY (voorkomt clickjacking via iframes)

- Referrer-Policy: strict-origin-when-cross-origin (beperkt doorsturen van URL-informatie)
 - Content-Security-Policy: beperkt welke externe bronnen de browser mag laden
 - Strict-Transport-Security: dwingt HTTPS af voor alle verbindingen
-

10. AFHANKELIJKHEIDSBEHEER

- Alle bekende kwetsbaarheden in npm-pakketten zijn verholpen (npm audit: van 39 naar 13 resterende meldingen, uitsluitend in build-time CLI-tools)
- Sanity CMS bijgewerkt van versie 3 naar versie 6 (actueel)
- Next.js, Clerk, jspdf en andere runtime-afhankelijkheden zijn bijgewerkt naar versies zonder bekende kwetsbaarheden
- Resterende meldingen betreffen uitsluitend ontwikkeltools die nooit in productie draaien

11. SERVERLESS TIMEOUTS

- Alle AI-routes hebben een geconfigureerde maximale looptijd (15 tot 60 seconden afhankelijk van de complexiteit)
 - Dit voorkomt ongecontroleerde API-kosten en resource-uitputting bij abnormale of kwaadwillende verzoeken
-

12. GEGEVENSEXPORT EN -VERWIJDERING (AVG)

- Gebruikers kunnen hun gegevens opvragen en exporteren via de accountpagina (recht op inzage, AVG art. 15)
- Verwijderverzoeken worden ingediend via de accountpagina en handmatig verwerkt binnen de wettelijke termijn (recht op vergetelheid, AVG art. 17)
- Bij verwijdering worden gesprekslogboeken en profielgegevens verwijderd, en het Clerk-account wordt gede-activeerd

13. CONTACT

Vragen over gegevensverwerking, beveiliging of het uitoefenen van AVG-rechten kunnen worden gestuurd naar: privacy@arno.bot